

ZAP by Checkmarx

Scanning Report

Generated with  ZAP on sam. 4 juil. 2026, at 18:12:45

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Contents

- [About This Report](#)
 - [Report Parameters](#)
- [Summaries](#)
 - [Alert Counts by Risk and Confidence](#)
 - [Alert Counts by Site and Risk](#)
 - [Alert Counts by Alert Type](#)
- [Alerts](#)
 - [Risk=Haut, Confidence=Moyen \(2\)](#)
 - [Risk=Moyen, Confidence=Haut \(4\)](#)
 - [Risk=Moyen, Confidence=Moyen \(3\)](#)
 - [Risk=Faible, Confidence=Haut \(3\)](#)
 - [Risk=Faible, Confidence=Moyen \(7\)](#)

-
- [Risk=Faible, Confidence=Faible \(1\)](#)
 - [Risk=Pour information, Confidence=Haut \(4\)](#)
 - [Risk=Pour information, Confidence=Moyen \(3\)](#)
 - [Risk=Pour information, Confidence=Faible \(2\)](#)
 - [Appendix](#)
 - [Alert Types](#)

About This Report

Report Parameters

Contexts

No contexts were selected, so all contexts were included by default.

Sites

The following sites were included:

- <https://fonts.gstatic.com>
- <https://fonts.googleapis.com>
- <https://archive.mozilla.org>
- <https://lototracker.goatcounter.com>
- <https://overpass-api.de>
- <https://xn--mto-bretagne-bebb.loto-tracker.fr>
- <https://gc.zgo.at>
- <https://c.tile.openstreetmap.org>
- <https://b.tile.openstreetmap.org>
- <https://a.tile.openstreetmap.org>
- <https://unpkg.com>
- <https://raw.githubusercontent.com>
- <https://content-signature-2.cdn.mozilla.net>
- <https://firefox-settings-attachments.cdn.mozilla.net>
- <https://firefox.settings.services.mozilla.com>

- <https://loto-tracker.fr>

(If no sites were selected, all sites were included by default.)

An included site must also be within one of the included contexts for its data to be included in the report.

Risk levels

Included: [Haut](#), [Moyen](#), [Faible](#), [Pour information](#)

Excluded: None

Confidence levels

Included: [User Confirmed](#), [Haut](#), [Moyen](#), [Faible](#)

Excluded: [User Confirmed](#), [Haut](#), [Moyen](#), [Faible](#), [Faux positif](#)

Summaries

Alert Counts by Risk and Confidence

This table shows the number of alerts for each level of risk and confidence included in the report.

(The percentages in brackets represent the count as a percentage of the total number of alerts included in the report, rounded to one decimal place.)

		Confidence				
		User Confirmed	Haut	Moyen	Faible	Total
Risk	Haut	0 (0,0 %)	0 (0,0 %)	2 (6,9 %)	0 (0,0 %)	2 (6,9 %)
	Moyen	0 (0,0 %)	4 (13,8 %)	3 (10,3 %)	0 (0,0 %)	7 (24,1 %)
	Faible	0 (0,0 %)	0 (0,0 %)	0 (0,0 %)	0 (0,0 %)	0 (0,0 %)

		Confidence				
		User				Total
		Confirmed	Haut	Moyen	Faible	
	Faible	0 (0,0 %)	3 (10,3 %)	7 (24,1 %)	1 (3,4 %)	11 (37,9 %)
	Pour information	0 (0,0 %)	4 (13,8 %)	3 (10,3 %)	2 (6,9 %)	9 (31,0 %)
	Total	0 (0,0 %)	11 (37,9 %)	15 (51,7 %)	3 (10,3 %)	29 (100%)

Alert Counts by Site and Risk

This table shows, for each site for which one or more alerts were raised, the number of alerts raised at each risk level.

Alerts with a confidence level of "False Positive" have been excluded from these counts.

(The numbers in brackets are the number of alerts raised for the site at or above that risk level.)

		Risk			
Site					Pour information
		Haut (= Haut)	Moyen (>= Moyen)	Faible (>= Faible)	(>= Pour information)
	https://xn--mto-bretagne-bebb.loto-tracker.fr	0 (0)	1 (1)	1 (2)	1 (3)
	https://content-signature-2.cdn.mozilla.net	0 (0)	0 (0)	1 (1)	0 (1)
	https://firefox.settings.services.mozilla.com	1 (1)	1 (2)	0 (2)	1 (3)

Risk				
	Haut (= Haut)	Moyen (>= Moyen)	Faible (>= Faible)	Pour information (>= Pour information)
https://loto-tracker.fr	1 (1)	5 (6)	9 (15)	7 (22)

Alert Counts by Alert Type

This table shows the number of alerts of each alert type, together with the alert type's risk level.

(The percentages in brackets represent each count as a percentage, rounded to one decimal place, of the total number of alerts included in this report.)

Alert type	Risk	Count
PII Disclosure	Haut	4 (13,8 %)
Vulnerable JS Library	Haut	1 (3,4 %)
CSP: Failure to Define Directive with No Fallback	Moyen	1 (3,4 %)
CSP: style-src unsafe-inline	Moyen	5 (17,2 %)
Content Security Policy (CSP) Header Not Set	Moyen	7 (24,1 %)
Mauvaise configuration inter-domaines	Moyen	27 (93,1 %)
Total		29

Alert type	Risk	Count
<u>Missing Anti-clickjacking Header</u>	Moyen	2 (6,9 %)
<u>Répertoire de navigation</u>	Moyen	5 (17,2 %)
<u>Sub Resource Integrity Attribute Missing</u>	Moyen	3 (10,3 %)
<u>Cookie No HttpOnly Flag</u>	Faible	1 (3,4 %)
<u>Cookie Without Secure Flag</u>	Faible	1 (3,4 %)
<u>Cookie with SameSite Attribute None</u>	Faible	10 (34,5 %)
<u>Cookie without SameSite Attribute</u>	Faible	1 (3,4 %)
<u>Cross-Domain JavaScript Source File Inclusion</u>	Faible	1 (3,4 %)
<u>In Page Banner Information Leak</u>	Faible	5 (17,2 %)
<u>Private IP Disclosure</u>	Faible	1 (3,4 %)
<u>Server Leaks Version Information via "Server" HTTP Response Header Field</u>	Faible	3 (10,3 %)
<u>Strict-Transport-Security Header Not Set</u>	Faible	20 (69,0 %)
<u>Timestamp Disclosure - Unix</u>	Faible	20 (69,0 %)
Total		29

Alert type	Risk	Count
<u>X-Content-Type-Options Header Missing</u>	Faible	24 (82,8 %)
<u>CSP: Header & Meta</u>	Pour information	1 (3,4 %)
<u>Content Security Policy (CSP) Report- Only Header Found</u>	Pour information	1 (3,4 %)
<u>Cookie faiblement couplé</u>	Pour information	5 (17,2 %)
<u>Information Disclosure - Information in Browser localStorage</u>	Pour information	19 (65,5 %)
<u>Information Disclosure - Information in Browser sessionStorage</u>	Pour information	18 (62,1 %)
<u>Information Disclosure - Suspicious Comments</u>	Pour information	25 (86,2 %)
<u>Modern Web Application</u>	Pour information	5 (17,2 %)
<u>Re-examine Cache-control Directives</u>	Pour information	17 (58,6 %)
<u>Retrieved from Cache</u>	Pour information	50 (172,4 %)
Total		29

Alerts

Risk=Haut, Confidence=Moyen (2)

<https://firefox.settings.services.mozilla.com> (1)

PII Disclosure (1)

► GET

[https://firefox.settings.services.mozilla.com/v1/buckets/main/collections/crash-reports-ondemand/changeset?
_expected=1783154298869](https://firefox.settings.services.mozilla.com/v1/buckets/main/collections/crash-reports-ondemand/changeset?_expected=1783154298869)

<https://loto-tracker.fr> (1)

Vulnerable JS Library (1)

► GET <https://loto-tracker.fr/assets/vendors/axios/axios.min.js>

Risk=Moyen, Confidence=Haut (4)

<https://xn--mto-bretagne-bebb.loto-tracker.fr> (1)

Sub Resource Integrity Attribute Missing (1)

► GET <https://xn--mto-bretagne-bebb.loto-tracker.fr/widget.html?lat=48.1173&lon=-1.6778&zoom=8>

<https://loto-tracker.fr> (3)

CSP: Failure to Define Directive with No Fallback (1)

► GET [https://loto-tracker.fr/cdn-cgi/content?
id=69bBYHuJRrpFIXCudikATN2RLRAKPZBlafZl4c4EQpc-
1783165073.534001-1.2.1.1-
20vvtPhv8WzjW7sCM22TzjUt1_AycI._TE.j5vW9DA0](https://loto-tracker.fr/cdn-cgi/content?id=69bBYHuJRrpFIXCudikATN2RLRAKPZBlafZl4c4EQpc-1783165073.534001-1.2.1.1-20vvtPhv8WzjW7sCM22TzjUt1_AycI._TE.j5vW9DA0)

CSP: style-src unsafe-inline (1)

► GET <https://loto-tracker.fr/dernier-tirage>

Content Security Policy (CSP) Header Not Set (1)

► GET <https://loto-tracker.fr/tirage/>

Risk=Moyen, Confidence=Moyen (3)

<https://firefox.settings.services.mozilla.com> (1)

Mauvaise configuration inter-domaines (1)

► GET <https://firefox.settings.services.mozilla.com/v1/>

<https://loto-tracker.fr> (2)

Missing Anti-clickjacking Header (1)

▼ GET https://loto-tracker.fr/cdn-cgi/content?id=69bBYHuJRrpFIXCudikATN2RLRAKPZBlafZl4c4EQpc-1783165073.534001-1.2.1.1-20vvtPhv8WzjW7sCM22TzjUt1_AycI._TE.j5vW9DA0

Alert tags

- [OWASP 2021 A05](#)
- POLICY_QA_STD =
- POLICY_PENTEST =
- [CWE-1021](#)
- [SYSTEMIC](#)
- [WSTG-v42-CLNT-09](#)
- [OWASP 2017 A06](#)
- [OWASP 2025 A02](#)

Alert description

The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.

Request

▼ Request line and header section (398 bytes)

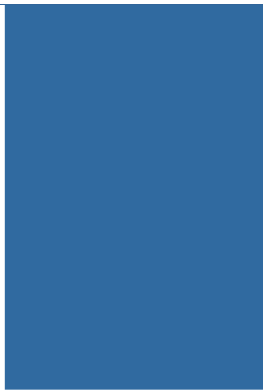
```
GET https://loto-tracker.fr/cdn-cgi/content?id=69bBYHuJRrpFIXCudikATN2RLRAKPZBla fZl4c4EQpc-1783165073.534001-1.2.1.1-20vvtPhv8WzjW7sCM22TzjUt1_AycI._TE.j5vW9DA0 HTTP/1.1
host: loto-tracker.fr
user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36
pragma: no-cache
cache-control: no-cache
referer: https://loto-tracker.fr
```

▼ Request body (0 bytes)

Response

▼ Status line and header section (543 bytes)

```
HTTP/1.1 200 OK
Date: Sat, 04 Jul 2026 11:37:53 GMT
Content-Type: text/html
Connection: keep-alive
Content-Security-Policy: default-src 'none'
Report-To: {"group":"cf-nel","max_age":604800,"endpoints":[{"url":"https://a.nel.cloudflare.com/report/v4?s=KLgr9BCuWYdeT4200V670xx3FFY09b83ATstKmFCnEl5qDGVeXQRjuh4ktRxU6EexV35PwYalSCnkC52coD%2Bv1GecMT0Wf5UHjhce375E9p%2B8oSZfaN8M3mXWYFM9ovOpLc%3D"}]}
Nel: {"report_to":"cf-nel","success_fraction":0.0,"max_age
```



```
":604800}  
Server: cloudflare  
CF-RAY: a15dd72f6ec24e73-CDG  
content-length: 4358
```

► Response body (4358 bytes)

Parameter

x-frame-options

Solution

Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app.

If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.

Répertoire de navigation (1)

► GET <https://loto-tracker.fr/admin/>

Risk=Faible, Confidence=Haut (3)

<https://content-signature-2.cdn.mozilla.net> (1)

Server Leaks Version Information via "Server" HTTP Response Header Field (1)

► GET <https://content-signature-2.cdn.mozilla.net/g/chains/202402/remote-settings.content-signature.mozilla.org-2026-08-15-13-10-18.chain>

<https://loto-tracker.fr> (2)

In Page Banner Information Leak (1)

► GET <https://loto-tracker.fr/tirage/>

Strict-Transport-Security Header Not Set (1)

► GET https://loto-tracker.fr/cdn-cgi/content?id=69bBYHuJRrpFIXCudikATN2RLRAKPZBlafZl4c4EQpc-1783165073.534001-1.2.1.1-20vvtPhv8WzjW7sCM22TzjUt1_AycI._TE.j5vW9DA0

Risk=Faible, Confidence=Moyen (7)

<https://xn--mto-bretagne-bebb.loto-tracker.fr> (1)

Cross-Domain JavaScript Source File Inclusion (1)

► GET <https://xn--mto-bretagne-bebb.loto-tracker.fr/widget.html?lat=48.1173&lon=-1.6778&zoom=8>

<https://loto-tracker.fr> (6)

Cookie No HttpOnly Flag (1)

► POST <https://loto-tracker.fr/api/auth/csrf>

Cookie Without Secure Flag (1)

► POST <https://loto-tracker.fr/api/auth/csrf>

Cookie with SameSite Attribute None (1)

► POST <https://loto-tracker.fr/cdn-cgi/challenge-platform/h/b/jsd/oneshot/80a697ecdece/0.12268507880832491:1783163134:zAWeszfvif-8FeDFW4mrY6a0wgP0KaZy49utWyVYo-c/a15dd91a19cc005a>

Cookie without SameSite Attribute (1)

► POST <https://loto-tracker.fr/api/auth/csrf>

Private IP Disclosure (1)

► GET <https://loto-tracker.fr/assets/js/index.js>

X-Content-Type-Options Header Missing (1)

► GET https://loto-tracker.fr/cdn-cgi/content?id=69bBYHuJRrpFIXCudikATN2RLRAKPZBlafZl4c4EQpc-1783165073.534001-1.2.1.1-20vvtPhv8WzjW7sCM22TzjUt1_AycI._TE.j5vW9DA0

Risk=Faible, Confidence=Faible (1)

<https://loto-tracker.fr> (1)

Timestamp Disclosure - Unix (1)

► GET https://loto-tracker.fr/politique_confidentialite.html

Risk=Pour information, Confidence=Haut (4)

<https://loto-tracker.fr> (4)

CSP: Header & Meta (1)

► GET https://loto-tracker.fr/cdn-cgi/content?id=69bBYHuJRrpFIXCudikATN2RLRAKPZBlafZl4c4EQpc-1783165073.534001-1.2.1.1-20vvtPhv8WzjW7sCM22TzjUt1_AycI._TE.j5vW9DA0

Content Security Policy (CSP) Report-Only Header Found (1)

► GET https://loto-tracker.fr/cdn-cgi/content?id=zrzm.nZ0cH0PbxEZ0VRZtkG_1420vngIS2HVfD1nCqA-1783165073.8110418-1.2.1.1-HBQgKeHE7jgAU7ZUAHMj_eTS4Z58RfL3mQYLP_0CgeM

Information Disclosure - Information in Browser localStorage (1)

► GET https://loto-tracker.fr/

Information Disclosure - Information in Browser sessionStorage (1)

► GET https://loto-tracker.fr/

Risk=Pour information, Confidence=Moyen (3)

https://firefox.settings.services.mozilla.com (1)

Retrieved from Cache (1)

► GET https://firefox.settings.services.mozilla.com/v1/

https://loto-tracker.fr (2)

Information Disclosure - Suspicious Comments (1)

► GET https://loto-tracker.fr/admin-login.html

Modern Web Application (1)

► GET https://loto-tracker.fr/tirage/

Risk=Pour information, Confidence=Faible (2)

<https://xn--mto-bretagne-bebb.loto-tracker.fr> (1)

Cookie faiblement couplé (1)

► POST <https://xn--mto-bretagne-bebb.loto-tracker.fr/cdn-cgi/challenge-platform/h/b/jsd/oneshot/80a697ecdece/0.12268507880832491:1783163134:zAWeszfvif-8FeDFW4mrY6a0wgP0KaZy49utWyVYo-c/a15dd92cce688f4>

<https://loto-tracker.fr> (1)

Re-examine Cache-control Directives (1)

► GET https://loto-tracker.fr/cdn-cgi/content?id=69bBYHuJRrpFIXCudikATN2RLRAKPZBlafZl4c4EQpc-1783165073.534001-1.2.1.1-20vvtPhv8WzjW7sCM22TzjUt1_AycI._TE.j5vW9DA0

Appendix

Alert Types

This section contains additional information on the types of alerts in the report.

PII Disclosure

Source	raised by a passive scanner (PII Disclosure)
CWE ID	359
WASC ID	13

Vulnerable JS Library

Source	raised by a passive scanner (Vulnerable JS Library (Powered by Retire.js))
CWE ID	1395
Reference	▪ https://owasp.org/Top10/A06_2021-Vulnerable_and_Outdated_Components/

CSP: Failure to Define Directive with No Fallback

Source	raised by a passive scanner (CSP)
CWE ID	693
WASC ID	15
Reference	▪ https://www.w3.org/TR/CSP/ ▪ https://caniuse.com/#search=content+security+policy ▪ https://content-security-policy.com/ ▪ https://github.com/HtmlUnit/htmlunit-csp ▪ https://web.dev/articles/csp#resource-options

CSP: style-src unsafe-inline

Source	raised by a passive scanner (CSP)
CWE ID	693
WASC ID	15
Reference	▪ https://www.w3.org/TR/CSP/

- <https://caniuse.com/#search=content+security+policy>
- <https://content-security-policy.com/>
- <https://github.com/HtmlUnit/htmlunit-csp>
- <https://web.dev/articles/csp#resource-options>

Content Security Policy (CSP) Header Not Set

Source	raised by a passive scanner (Content Security Policy (CSP) Header Not Set)
CWE ID	693
WASC ID	15
Reference	▪ https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP ▪ https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html ▪ https://www.w3.org/TR/CSP/ ▪ https://w3c.github.io/webappsec-csp/ ▪ https://web.dev/articles/csp ▪ https://caniuse.com/#feat=contentsecuritypolicy ▪ https://content-security-policy.com/

Mauvaise configuration inter-domaines

Source	raised by a passive scanner (Mauvaise configuration inter-domaines)
CWE ID	264
WASC ID	14
Reference	▪ https://vulncat.fortify.com/en/detail?category=HTML5&subcategory=Overly%20Permissive%20CORS%20Policy

Missing Anti-clickjacking Header

Source	raised by a passive scanner (Anti-clickjacking Header)
CWE ID	1021
WASC ID	15
Reference	▪ https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options

Répertoire de navigation

Source	raised by a passive scanner (Répertoire de navigation)
CWE ID	548
WASC ID	16
Reference	▪ https://cwe.mitre.org/data/definitions/548.html

Sub Resource Integrity Attribute Missing

Source	raised by a passive scanner (Sub Resource Integrity Attribute Missing)
CWE ID	345
WASC ID	15
Reference	▪ https://developer.mozilla.org/en-US/docs/Web/Security/Subresource_Integrity

Cookie No HttpOnly Flag

Source	raised by a passive scanner (Cookie No HttpOnly Flag)
CWE ID	1004
WASC ID	13
Reference	▪ https://owasp.org/www-community/HttpOnly

Cookie Without Secure Flag

Source	raised by a passive scanner (Cookie Without Secure Flag)
CWE ID	614
WASC ID	13
Reference	▪ https://owasp.org/www-project-web-security-testing-guide/v41/4-Web_Application_Security_Testing/06-Session_Management_Testing/02-Testing_for_Cookies_Attributes.html

Cookie with SameSite Attribute None

Source	raised by a passive scanner (Cookie without SameSite Attribute)
CWE ID	1275
WASC ID	13
Reference	▪ https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site

Cookie without SameSite Attribute

Source	raised by a passive scanner (Cookie without SameSite Attribute)
CWE ID	1275
WASC ID	13
Reference	▪ https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site

Cross-Domain JavaScript Source File Inclusion

Source	raised by a passive scanner (Cross-Domain JavaScript Source File Inclusion)
CWE ID	829
WASC ID	15

In Page Banner Information Leak

Source	raised by a passive scanner (In Page Banner Information Leak)
CWE ID	497
WASC ID	13

Reference

- https://owasp.org/www-project-web-security-testing-guide/v41/4-Web_Application_Security_Testing/08-Testing_for_Error_Handling/

Private IP Disclosure

Source

raised by a passive scanner ([Private IP Disclosure](#))

CWE ID

[497](#)

WASC ID

13

Reference

- <https://datatracker.ietf.org/doc/html/rfc1918>

Server Leaks Version Information via "Server" HTTP Response Header Field

Source

raised by a passive scanner ([HTTP Server Response Header](#))

CWE ID

[497](#)

WASC ID

13

Reference

- <https://httpd.apache.org/docs/current/mod/core.html#servertokens>
- [https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552\(v=pandp.10\)](https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10))
- <https://www.troyhunt.com/shhh-dont-let-your-response-headers/>

Strict-Transport-Security Header Not Set

Source	raised by a passive scanner (Strict-Transport-Security Header)
CWE ID	319
WASC ID	15
Reference	▪ https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Strict_Transport_Security_Cheat_Sheet.html ▪ https://owasp.org/www-community/Security-Headers ▪ https://en.wikipedia.org/wiki/HTTP_Strict_Transport_Security ▪ https://caniuse.com/stricttransportsecurity ▪ https://datatracker.ietf.org/doc/html/rfc6797

Timestamp Disclosure - Unix

Source	raised by a passive scanner (Timestamp Disclosure)
CWE ID	497
WASC ID	13
Reference	▪ https://cwe.mitre.org/data/definitions/200.html

X-Content-Type-Options Header Missing

Source	raised by a passive scanner (X-Content-Type-Options Header Missing)
CWE ID	693
WASC ID	15
Reference	▪ https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) ▪ https://owasp.org/www-community/Security-Headers

CSP: Header & Meta

Source	raised by a passive scanner (CSP)
CWE ID	693
WASC ID	15
Reference	▪ https://www.w3.org/TR/CSP/ ▪ https://caniuse.com/#search=content+security+policy ▪ https://content-security-policy.com/ ▪ https://github.com/HtmlUnit/htmlunit-csp ▪ https://web.dev/articles/csp#resource-options

Content Security Policy (CSP) Report-Only Header Found

Source	raised by a passive scanner (Content Security Policy (CSP) Header Not Set)
---------------	--

CWE ID	<u>693</u>
WASC ID	15
Reference	▪ https://www.w3.org/TR/CSP2/ ▪ https://w3c.github.io/webappsec-csp/ ▪ https://caniuse.com/#feat=contentsecuritypolicy ▪ https://content-security-policy.com/

Cookie faiblement couplé

Source	raised by a passive scanner (Cookie faiblement couplé)
CWE ID	<u>565</u>
WASC ID	15
Reference	▪ https://datatracker.ietf.org/doc/html/rfc6265#section-4.1 ▪ https://owasp.org/www-project-web-security-testing-guide/v41/4-Web_Application_Security_Testing/06-Session_Management_Testing/02-Testing_for_Cookies_Attributes.html ▪ https://code.google.com/archive/p/browsersec/wikis/Part2.wiki

Information Disclosure - Information in Browser localStorage

Source	raised by a passive scanner (plugin ID: 120000)
---------------	---

CWE ID	359
--------	---------------------

WASC ID	13
---------	----

Information Disclosure - Information in Browser sessionStorage

Source	raised by a passive scanner (plugin ID: 120000)
--------	---

CWE ID	359
--------	---------------------

WASC ID	13
---------	----

Information Disclosure - Suspicious Comments

Source	raised by a passive scanner (Information Disclosure - Suspicious Comments)
--------	--

CWE ID	615
--------	---------------------

WASC ID	13
---------	----

Modern Web Application

Source	raised by a passive scanner (Modern Web Application)
--------	--

Re-examine Cache-control Directives

Source	raised by a passive scanner (Re-examine Cache-control Directives)
--------	---

CWE ID	525
--------	---------------------

WASC ID	13
---------	----

Reference	■ https://cheatsheetseries.owasp.org/cheatsheet
-----------	---

[s/Session Management Cheat Sheet.html#web-content-caching](https://www.session-management.com/Session_Management_Cheat_Sheet.html#web-content-caching)

- <https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cache-Control>
- <https://grayduck.mn/2021/09/13/cache-control-recommendations/>

Retrieved from Cache

Source

raised by a passive scanner ([Retrieved from Cache](#))

CWE ID

[525](#)

Reference

- <https://datatracker.ietf.org/doc/html/rfc7234>
- <https://datatracker.ietf.org/doc/html/rfc7231>
- <https://www.rfc-editor.org/rfc/rfc9110.html>